

112 學年第 1 學期

輔仁大學

人工智慧與資訊安全學士學位學程

期中報告

Threat Hunting Essential

Attack Recognition Techniques

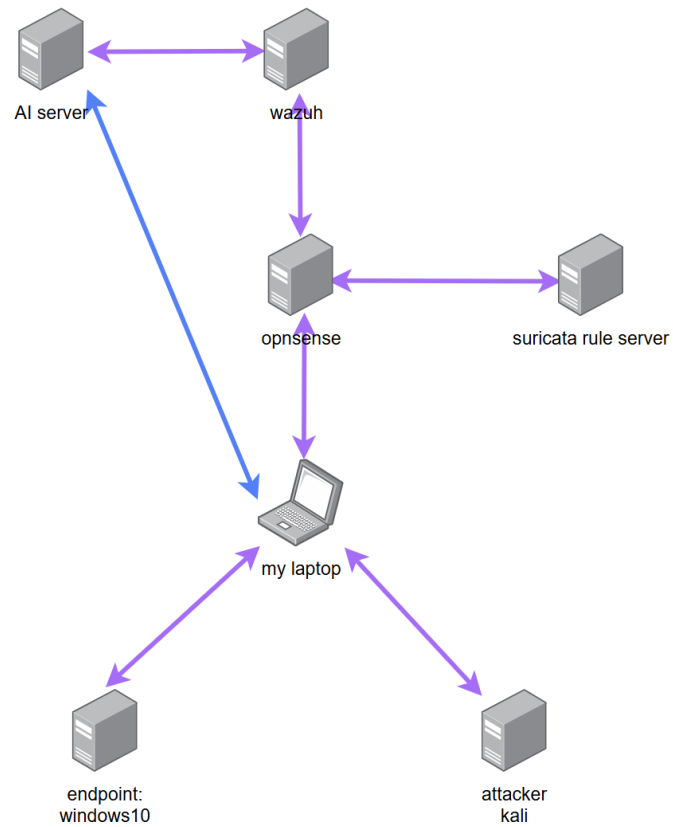
目錄

第一章、 環境設置.....	4
第一節、 整體架構	4
第二節、 架構說明	5
第二章、 網路設定.....	6
第一節、 網路設定困境討論	6
第二節、 我的想法	7
第三章、 成果展示.....	9
第一節、 偵測 nmap、SSH、rustdesk.....	9
第二節、 將產生的 Snort event 的描述改為 Snort 的 msg.....	13
第三節、 偵測電腦開的程序(打開 calc.exe).....	14
第四節、 偵測連續多次相同行為(ex: 多次輸入錯誤密碼).....	15
第五節、 偵測 Windows 遠端桌面	16
第六節、 偵測 powershell 使用到 curl 等常見下載指令	16
第四章、 MCP server 討論	18
第一節、 修改 wazuh indexer 設定檔案	18
第二節、 設定 mcp server.....	19

第三節、 結果展示	20
第四節、 問題討論	22
第五章、 未來展望	24

第一章、環境設置

第一節、整體架構



圖一、作業整體的架構圖

這是完整的架構圖，設備會用到:

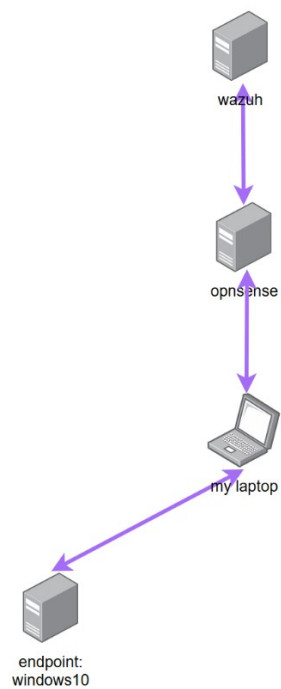
- 伺服器(pve)
 - wazuh server
 - opnsense
 - Suricate rule server
 - vpn server(wireguard)

- 本機虛擬器軟體(vmware workstation pro)
- windows 10 vm
- Kali vm
- AI server (windows 11)

第二節、 架構說明

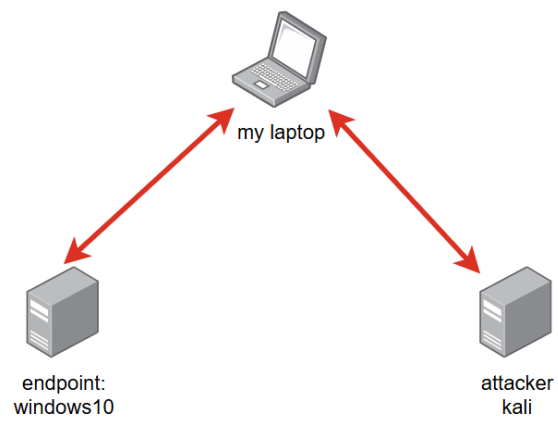
從 windows 10 端點遇到作業問題會先經過 opnsense 然後才會是 wazuh ,

具體如下圖二



圖二、端點 windows 到 wazuh 的流程

然後端點 kali 和端點 windows 間亦有連結，具體如下圖三



圖三、端點 windows 和 kali 架構

第二章、網路設定

第一節、網路設定困境討論

雖然把整體的東西分散可以讓每個設備運行不會負擔這麼大，但是網路問題往往會非常的折磨人，於是在說明具體作法前，我們可以先看設備間網路的關係。

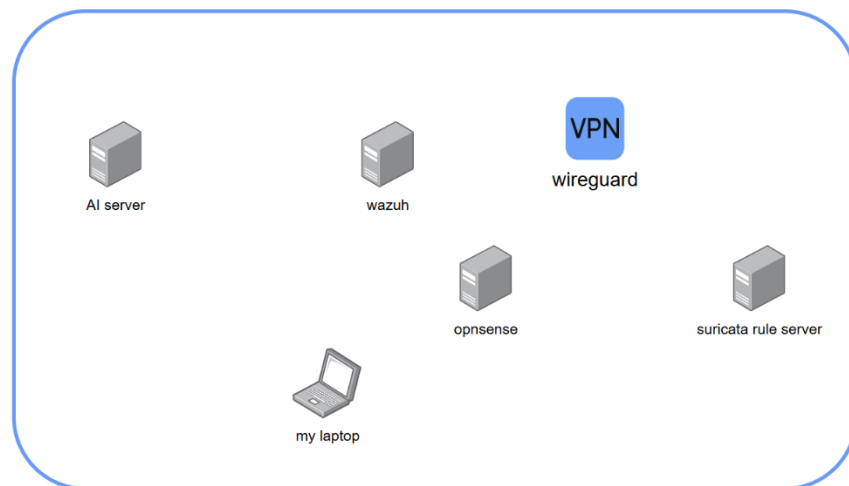


圖四、設備間的網路關係圖，每個方框都是不同的子網(subnetwork)

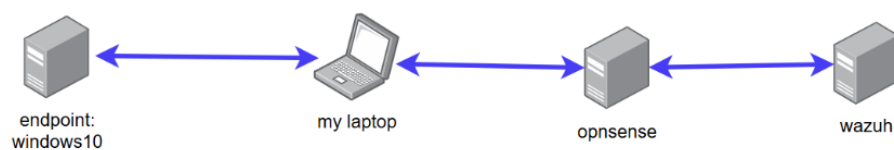
第二節、 我的想法

所以要統合起來，我是這樣設計的。

首先，先設計一個子網，將我筆電、和伺服器內的設備用 VPN 連結成一個大內網，方便我存取裡面的資源(具體見圖五)。接著，AI server 和我的電腦間會用另外獨立的 VPN 去做存取(由於該設備在我家中，是故本篇文章不會著墨於此)。最後，我會在 opnsense 中在建立一個 VPN 去讓端點 windows 10 的網路流量會全部導入 opnsense 的 suricata 中，同時也會讓 kali 可以訪問到。(見圖六)

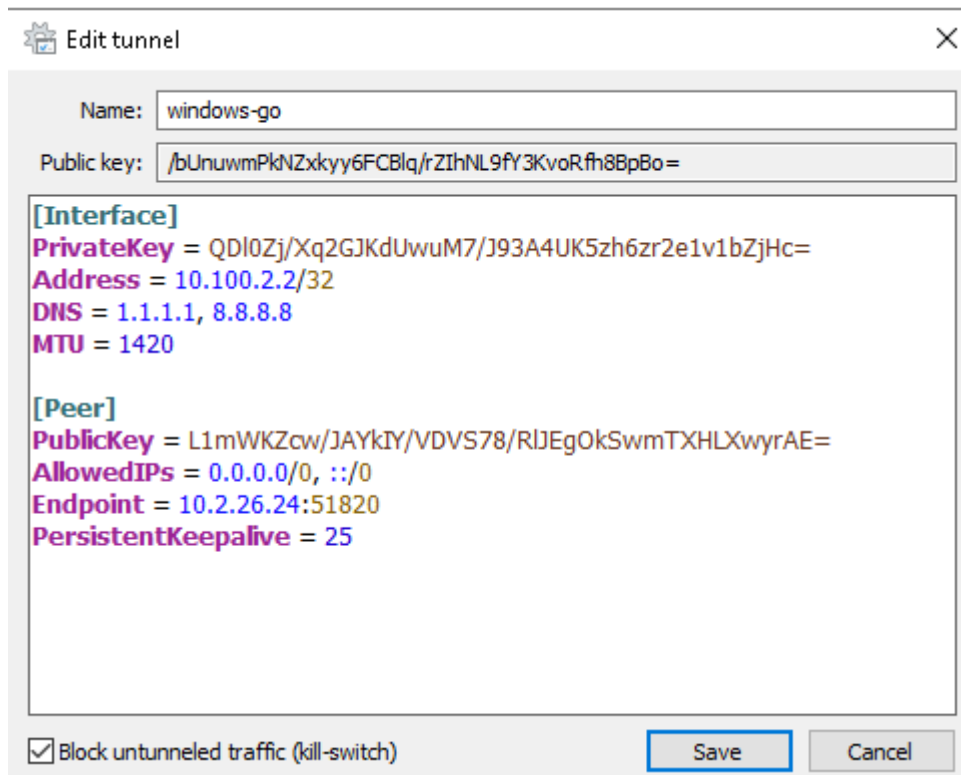


圖五、我會將這些設備統一劃入到 vpn 內網內



圖六、所有在 windows 上的流量都會經過 opnsense，如果觸發 opnsense 中的規則，則會將報告上傳到 wazuh

所有的東西我都用 wireguard 去實現，其中端點 window10 比較特別，因為要把所有流量都導入到 opnsense 中，所以寫在端點 window10 的 wireguard 設定檔可以參考圖七

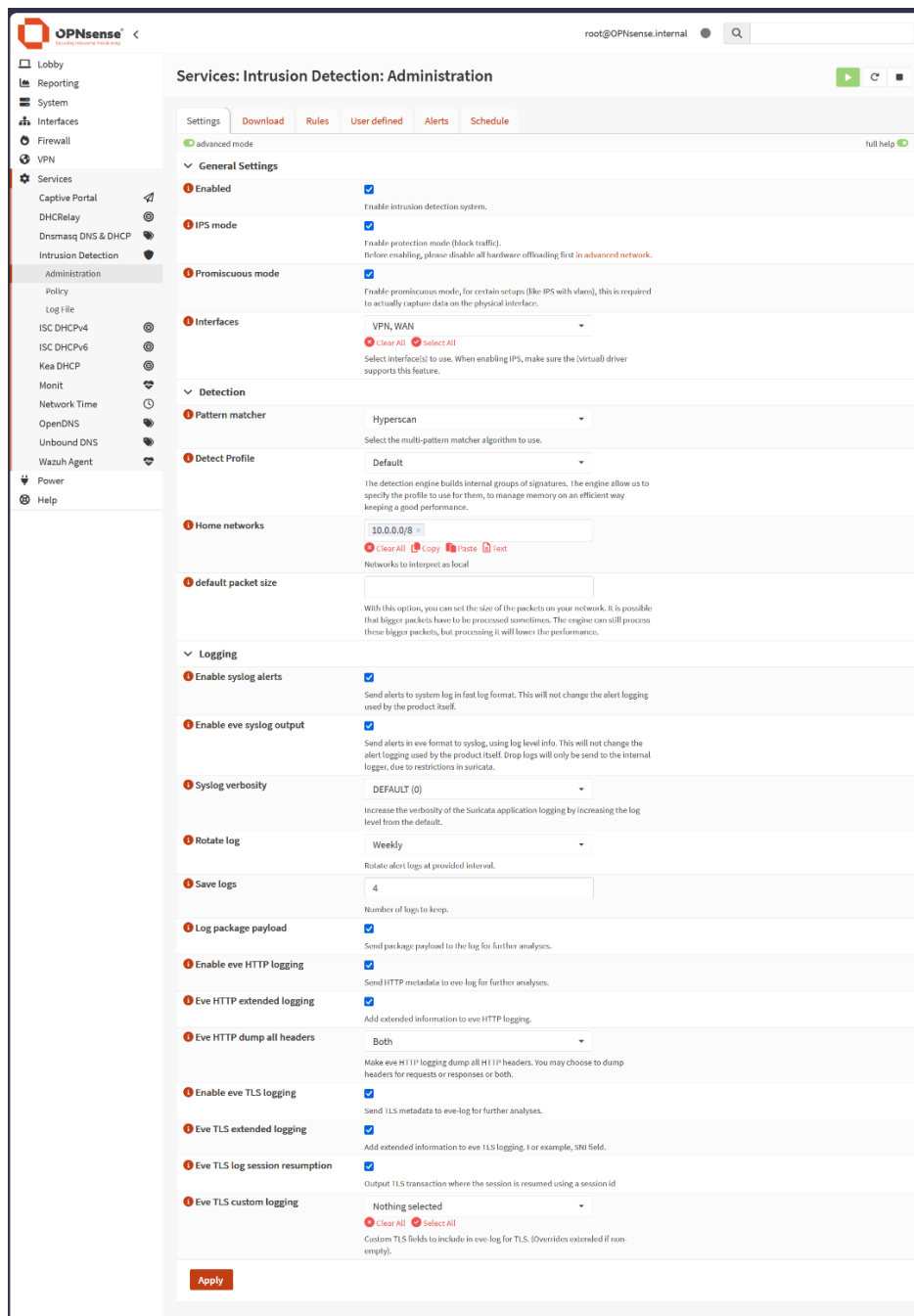


圖七、wireguard 設定檔參考設定

第三章、 成果展示

第一節、 偵測 nmap、SSH、rustdesk

opnsense 內建 Intrusion Detection 的功能，並且其使用 suricata。所以可以我先照下圖設定該功能。



圖八、這是我 suricata 的設定

可是，我沒辦法自訂規則，是故，suricata rule server 派上用場了。

我在 surecata rule server 裡寫兩個檔案，分別是 custom.xml 和

custom.rules，具體如以下兩張圖。

```
<?xml version="1.0"?>
<ruleset documentation_url="http://docs.opnsense.org/">
  <location url="http://10.2.26.25/" prefix="custom"/>
  <files>
    <file description="custom rules">custom.rules</file>
    <file description="custom" url="inline::rules/custom.rules">custom.rules</file>
  </files>
</ruleset>
```

圖九、custom.xml

```
# CUSTOM RULESET FOR TEST
# Nmap / SSH / Rustdesk
#
# — NMAP SCANS —
alert tcp any any → any any (flags:S; msg:"CUSTOM: Nmap SYN scan detected"; sid:900001; rev:1;)
alert tcp any any → any any (flags:0; msg:"CUSTOM: Nmap NULL scan detected"; sid:900002; rev:1;)
alert tcp any any → any any (flags:F; msg:"CUSTOM: Nmap FIN scan detected"; sid:900003; rev:1;)
alert tcp any any → any any (flags:FAUP; msg:"CUSTOM: Nmap Xmas scan detected"; sid:900004; rev:1;)
# — SSH —
alert tcp any any → any 22 (msg:"CUSTOM: SSH connection attempt"; sid:900010; rev:1;)
alert tcp any any → any 22 (flags:S; threshold:type both,track by_src,count 5,seconds 10; msg:"CUSTOM: SSH scanning behavior detected"; sid:900011; rev:1;)
alert tcp any any → any 22 (threshold:type threshold,track by_src,count 15,seconds 60; msg:"CUSTOM: SSH brute force attempt"; sid:900012; rev:1;)
# — RUSTDESK —
alert tcp any any → any 21116 (msg:"CUSTOM: Rustdesk Relay connection"; sid:900020; rev:1;)
alert udp any any → any 21116 (msg:"CUSTOM: Rustdesk Relay UDP traffic"; sid:900021; rev:1;)
alert tcp any any → any 21115 (msg:"CUSTOM: Rustdesk ID Server traffic"; sid:900022; rev:1;)
alert udp any any → any any (dsize:>50; threshold:type both,track by_src,count 100,seconds 5; msg:"CUSTOM: Rustdesk P2P-like UDP burst"; sid:900023; rev:1;)
```

圖十、custom.rules

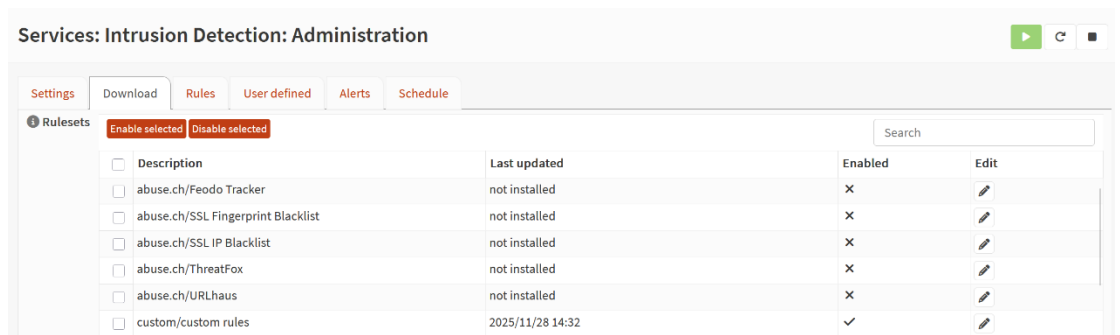
然後用 scp 指令將 custom.xml 檔案放入 opnsense 裡面，並且用 python

打開 http server。具體如下圖

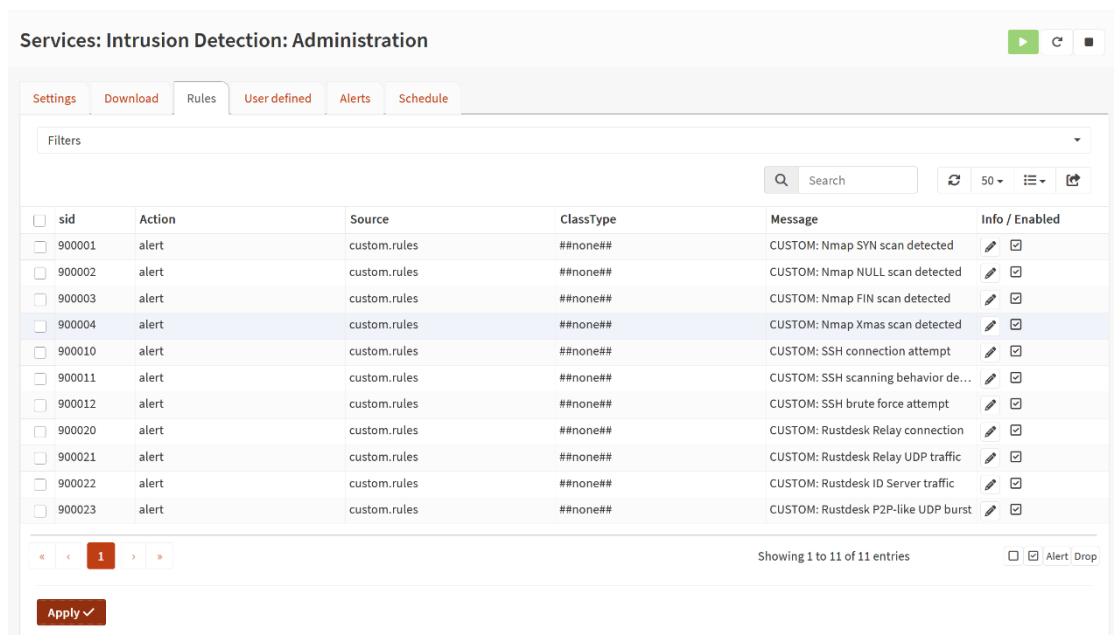
```
nisra@nisra:~$ sudo python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.100.0.101 - - [28/Nov/2025 14:31:37] "GET / HTTP/1.1" 200 -
10.2.26.24 - - [28/Nov/2025 14:32:07] "GET /custom.rules HTTP/1.1" 200 -
```

圖十一、http server 使用 python，圖中可以看到有兩個 IP 嘗試存取此設備，一個是我的電腦，另外一個則是 opnsense

這樣，把 Intrusion Detection 的服務重啟後，並更新規則後，就可以成功使用我們自訂的內容。具體如下兩張圖

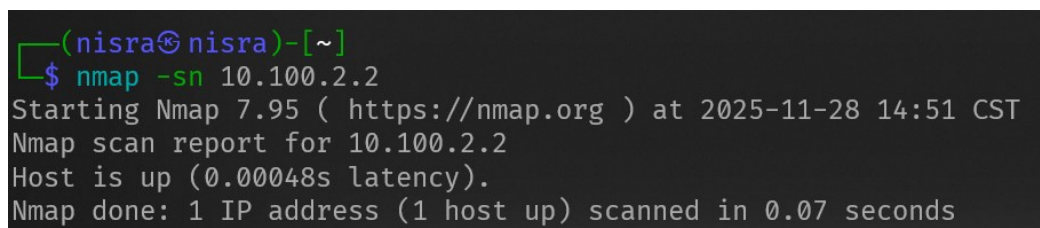


圖十二、規則已經成功寫入 opnsense 中了



圖十三、可以看到自訂規則可以在 rules 自由使用了

這些做完之後，使用 kali 去使用 nmap 即可在 opnsense 和 wazuh 收到警告(alert)



圖十四、kali 使用的指令和其結果

Services: Intrusion Detection: Administration

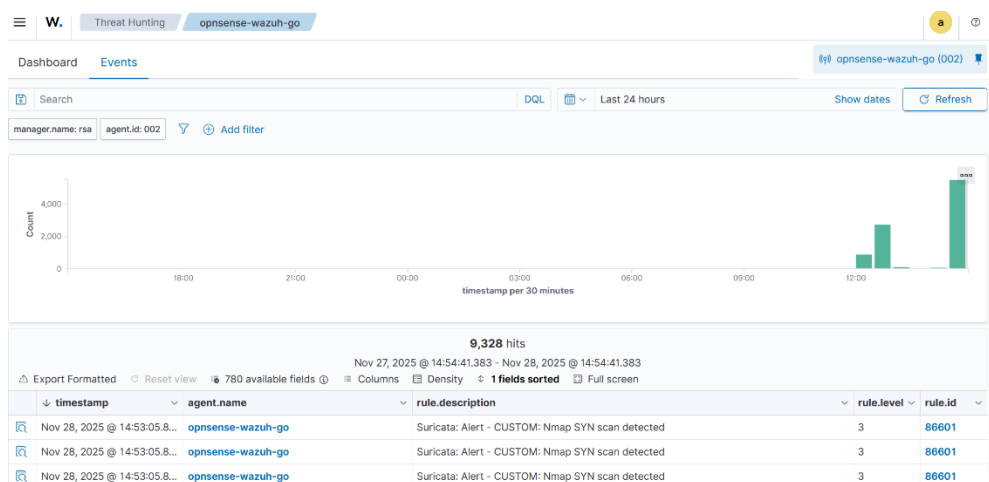
Settings Download Rules User defined Alerts Schedule

Search [icon] [icon] 2025/11/28 14:51 50 [icon]

Timestamp	SID	Action	Interface	Source	Port	Destination	Port	Alert	Info
2025-11-28T14:51:54.995196+0800	900001	allowed	VPN	10.100.2.1	41572	10.100.2.2	443	CUSTOM: Nmap SYN scan detected	[icon]
2025-11-28T14:51:54.994895+0800	900001	allowed	VPN	10.100.2.1	41572	10.100.2.2	443	CUSTOM: Nmap SYN scan detected	[icon]
2025-11-28T14:51:54.471927+0800	900001	allowed	VPN	10.100.2.1	41572	10.100.2.2	443	CUSTOM: Nmap SYN scan detected	[icon]
2025-11-28T14:51:54.471697+0800	900001	allowed	VPN	10.100.2.1	41572	10.100.2.2	443	CUSTOM: Nmap SYN scan detected	[icon]
2025-11-28T14:51:53.952945+0800	900001	allowed	VPN	10.100.2.1	41572	10.100.2.2	443	CUSTOM: Nmap SYN scan detected	[icon]
2025-11-28T14:51:53.952252+0800	900001	allowed	VPN	10.100.2.1	41572	10.100.2.2	443	CUSTOM: Nmap SYN scan detected	[icon]
2025-11-28T14:51:53.439695+0800	900001	allowed	VPN	10.100.2.1	41572	10.100.2.2	443	CUSTOM: Nmap SYN scan detected	[icon]
2025-11-28T14:51:53.439454+0800	900001	allowed	VPN	10.100.2.1	41572	10.100.2.2	443	CUSTOM: Nmap SYN scan detected	[icon]
2025-11-28T14:51:52.923665+0800	900001	allowed	VPN	10.100.2.1	41572	10.100.2.2	443	CUSTOM: Nmap SYN scan detected	[icon]
2025-11-28T14:51:52.923316+0800	900001	allowed	VPN	10.100.2.1	41572	10.100.2.2	443	CUSTOM: Nmap SYN scan detected	[icon]
2025-11-28T14:51:47.499704+0800	900001	allowed	WAN	10.2.26.24	3324	10.2.26.23	1514	CUSTOM: Nmap SYN scan detected	[icon]
2025-11-28T14:51:47.499345+0800	900001	allowed	VPN	10.100.2.2	50965	10.2.26.23	1514	CUSTOM: Nmap SYN scan detected	[icon]

Showing 1 to 12 of 12 entries

圖十五、opnsense 收到的警告



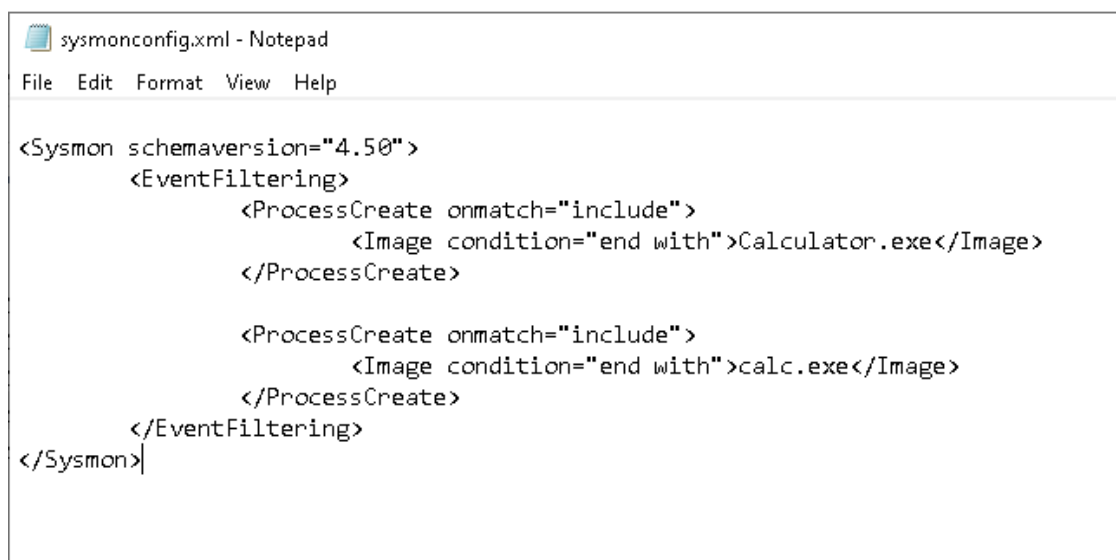
圖十六、wazuh 收到的警告

第二節、 將產生的 Snort event 的描述 (IDS event) 改為 Snort 的 msg

因為我是用 suricata ，使用第一節的規則，在成功被偵測到後，wazuh 就會顯示 suricata 的訊息，所以不多做贅述。

第三節、偵測電腦開的程序(打開 calc.exe)

首先先下載 sysmon，然後寫 sysmonconfig.xml(詳見圖十七)，在該目錄下使用 Sysmon.exe -c sysmonconfig.xml(需用管理員權限)，然後在 wazuh agent 的規則中寫相關內容(見圖十八)，最後在 wazuh server 中的 /var/ossec/etc/rules/local_rules.xml 中寫入圖十九的內容。並且使用指令 systemctl restart wazuh-manager(需用管理員權限) 即可。



圖十七、sysmonconfig.xml 的偵測小算盤的設定

```
<localfile>
  <location>Microsoft-Windows-Sysmon/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>
```

圖十八、wazuh agent 中 ossec.conf 裡 sysmon 的設定內容

```
<group name="local,sysmon,windows,calc">

  <rule id="900010" level="5">
    <if_sid>61603</if_sid>
    <field name="win.eventdata.Image">calc.exe</field>
    <description>windows open calculator app</description>
  </rule>

</group>
```

圖十九、圖內為使用小算盤(calc.exe)然後被偵測的部分規則

	Dec 2, 2025 @ 18:09:44.469	windows-go2	windows open calculator app	5	900010
	Dec 2, 2025 @ 18:09:27.486	windows-go2	windows open calculator app	5	900010
	Dec 2, 2025 @ 18:03:48.780	windows-go2	windows open calculator app	5	900010
	Dec 2, 2025 @ 18:02:58.001	windows-go2	windows open calculator app	5	900010

圖二十、偵測結果

第四節、 偵測連續多次相同行為(ex: 多次輸入錯誤密碼)

規則 60122 本身可以偵測到密碼輸入錯誤的情況，所以加上條件即可有結果

```
<group name="local,sysmon,windows,logon">

  <rule id="900020" level="12" frequency="6" timeframe="60">
    <if_matched_sid>60122</if_matched_sid>
    <description>Multiple logon failure - Unknown user or bad password.</description>
  </rule>

</group>
```

圖二十一、圖內為多次輸入 windows 系統登入密碼錯誤的規則

然後使用在虛擬機上測試後會得到以下結果

	Dec 2, 2025 @ 17:55:52.390	windows-go2	Multiple logon failure - Unknown user or bad password.	12	900020
	Dec 2, 2025 @ 17:55:47.013	windows-go2	Logon Failure - Unknown user or bad password	5	60122
	Dec 2, 2025 @ 17:55:39.115	windows-go2	Logon Failure - Unknown user or bad password	5	60122
	Dec 2, 2025 @ 17:55:21.405	windows-go2	Logon Failure - Unknown user or bad password	5	60122
	Dec 2, 2025 @ 17:55:19.805	windows-go2	Logon Failure - Unknown user or bad password	5	60122
	Dec 2, 2025 @ 17:55:17.957	windows-go2	Logon Failure - Unknown user or bad password	5	60122
	Dec 2, 2025 @ 17:55:14.947	windows-go2	Windows User Logoff	3	60137

圖二十二、偵測結果

第五節、 偵測 Windows 遠端桌面

這其實有 wazuh 本身就可以偵測到了，所以就把規則 92652 重新打包即可

```
<group name="local,sysmon,windows,rdp">

  <rule id="900030" level="10">
    <if_sid>92652</if_sid>
    <description>windows rdp login</description>
  </rule>

</group>
```

圖二十三、 windows rdp 規則

	Dec 2, 2025 @ 17:54:32.559	windows-go2	Special privileges assigned to new logon.	3	67028
	Dec 2, 2025 @ 17:54:32.653	windows-go2	Windows User Logoff	3	60137
	Dec 2, 2025 @ 17:54:32.636	windows-go2	windows rdp login	10	900030
	Dec 2, 2025 @ 17:54:32.629	windows-go2	Special privileges assigned to new logon.	3	67028
	Dec 2, 2025 @ 17:54:32.623	windows-go2	Special privileges assigned to new logon.	3	67028

圖二十四、 偵測結果

第六節、 偵測 powershell command line 使用到 curl/wget 等常

見下載指令

因為我們需要先讓 windows 可以把 powershell 的運行的 script block 日誌傳到 wazuh，所以先用圖二十三中的指令開 powershell 的日誌功能。然後使用圖二十四中的內容讓 powershell 日誌傳到 wazuh server，最後最難的是設定規則。

為了讓 curl 順利被偵測到，需先偵測 powershell 日誌的功能，然後是 powershell 日誌功能中 script block 的內容，最後再從 script block 的內容中找 curl 指令。

```
PS C:\Windows\system32> function Enable-PSLogging {
>> # Define registry paths for ScriptBlockLogging and ModuleLogging
>> $scriptBlockPath = 'HKLM:\Software\Policies\Microsoft\Windows\PowerShell\ScriptBlockLogging'
>> $moduleLoggingPath = 'HKLM:\Software\Policies\Microsoft\Windows\PowerShell\ModuleLogging'
>>
>> # Enable Script Block Logging
>> if (-not (Test-Path $scriptBlockPath)) {
>>     $null = New-Item $scriptBlockPath -Force
>> }
>> Set-ItemProperty -Path $scriptBlockPath -Name EnableScriptBlockLogging -Value 1
>>
>> # Enable Module Logging
>> if (-not (Test-Path $moduleLoggingPath)) {
>>     $null = New-Item $moduleLoggingPath -Force
>> }
>> Set-ItemProperty -Path $moduleLoggingPath -Name EnableModuleLogging -Value 1
>>
>> # Specify modules to log - set to all (*) for comprehensive logging
>> $moduleNames = @('*') # To specify individual modules, replace * with module names in the array
>> New-ItemProperty -Path $moduleLoggingPath -Name ModuleNames -PropertyType MultiString -Value $moduleNames -Force
>>
>> Write-Output "Script Block Logging and Module Logging have been enabled."
>> }
>> Enable-PSLogging_
```

圖二十五、開啟 powershell 日誌功能

```
<localfile>
  <location>Microsoft-Windows-PowerShell/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>

<localfile>
  <location>Windows PowerShell</location>
  <log_format>eventchannel</log_format>
</localfile>
```

圖二十六、wazuh agent 中 ossec.conf 裡 powershell log 設定內容

```
<group name="local,sysmon,windows,pwsh">
  <rule id="900040" level="0">
    <if_sid>60000, 60010</if_sid>
    <field name="win.system.channel">^Microsoft-Windows-PowerShell/Operational$</field>
    <options>no_full_log</options>
    <description>Group of windows rules for the PowerShell</description>
  </rule>

  <rule id="900041" level="0">
    <if_sid>900040</if_sid>
    <field name="win.eventdata.ScriptBlockID" type="pcre2">.+</field>
    <options>no_full_log</options>
    <description>Group of windows rules for the PowerShell</description>
  </rule>

  <rule id="900042" level="10">
    <if_sid>900041</if_sid>
    <field name="win.eventdata.scriptBlockText" type="pcre2">(?!i)curl</field>
    <description>PowerShell executed curl command (possible download activity).</description>
  </rule>
</group>
```

圖二十七、偵測 powershell 使用 curl 的規則

 Dec 2, 2025 @ 18:28:01.514 windows-go2	PowerShell executed curl command (possible download activity).	6	900040
 Dec 2, 2025 @ 18:27:33.608 windows-go2	PowerShell executed curl command (possible download activity).	6	900040

圖二十八、偵測結果

第四章、 MCP server 討論

如若 MCP server 和我的 AI server 放在一起，但這又會遇到，wazuh indexer 只聽 localhost:9200 port。所以在我們快快樂樂地編輯 mcp 前需要
先修改某些設定。

第一節、 修改 wazuh indexer 設定檔案

在 wazuh server 中修改 wazuh indexer 的設定檔案，讓 server 不會只聽 localhost。

```

network.host: "0.0.0.0"
node.name: "node-1"
cluster.initial_master_nodes:
- "node-1"
cluster.name: "wazuh-cluster"

node.max_local_storage_nodes: "3"
path.data: /var/lib/wazuh-indexer
path.logs: /var/log/wazuh-indexer

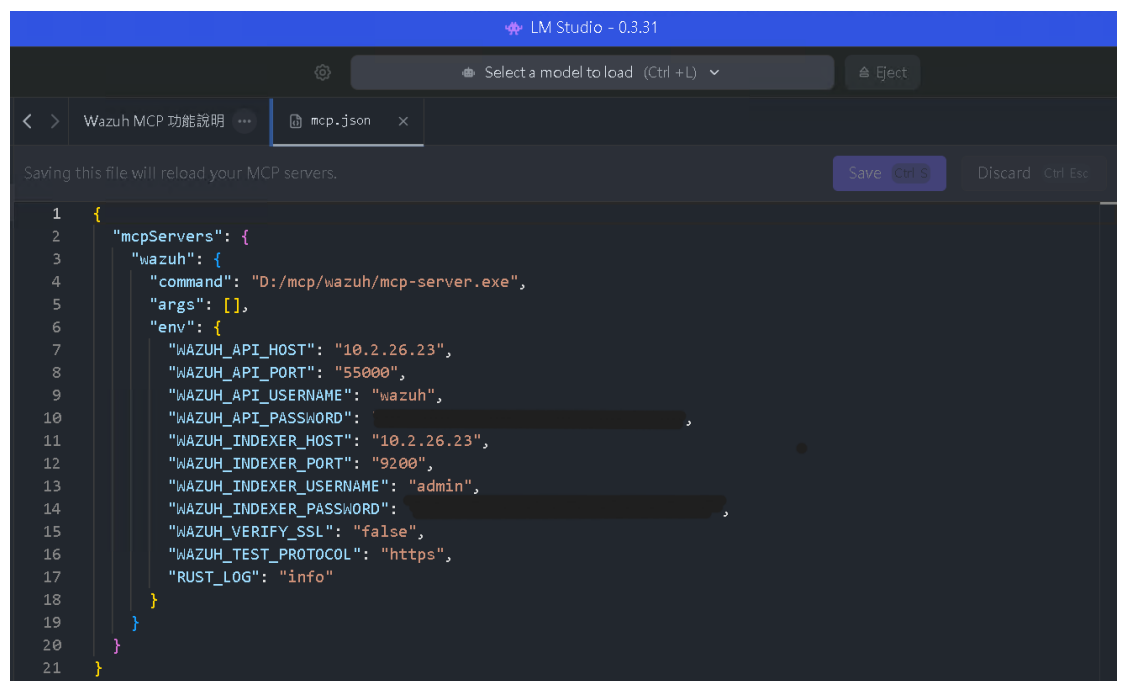
plugins.security.ssl.http.pemcert_filepath: /etc/wazuh-indexer/certs/wazuh-indexer.pem
plugins.security.ssl.http.pemkey_filepath: /etc/wazuh-indexer/certs/wazuh-indexer-key.pem
plugins.security.ssl.http.pemtrustedcas_filepath: /etc/wazuh-indexer/certs/root-ca.pem
plugins.security.ssl.transport.pemcert_filepath: /etc/wazuh-indexer/certs/wazuh-indexer.pem
plugins.security.ssl.transport.pemkey_filepath: /etc/wazuh-indexer/certs/wazuh-indexer-key.pem
plugins.security.ssl.transport.pemtrustedcas_filepath: /etc/wazuh-indexer/certs/root-ca.pem
plugins.security.ssl.http.enabled: true
plugins.security.ssl.transport.enforce_hostname_verification: false
plugins.security.ssl.transport.resolve_hostname: false
plugins.security.ssl.http.enabled_ciphers:
- "TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256"
- "TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384"
- "TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256"
"/etc/wazuh-indexer/opensearch.yml" 41L, 2150B 10,0-1 Top

```

圖二十九、/etc/wazuh-indexer/opensearch.yml 設定

第二節、設定 mcp server

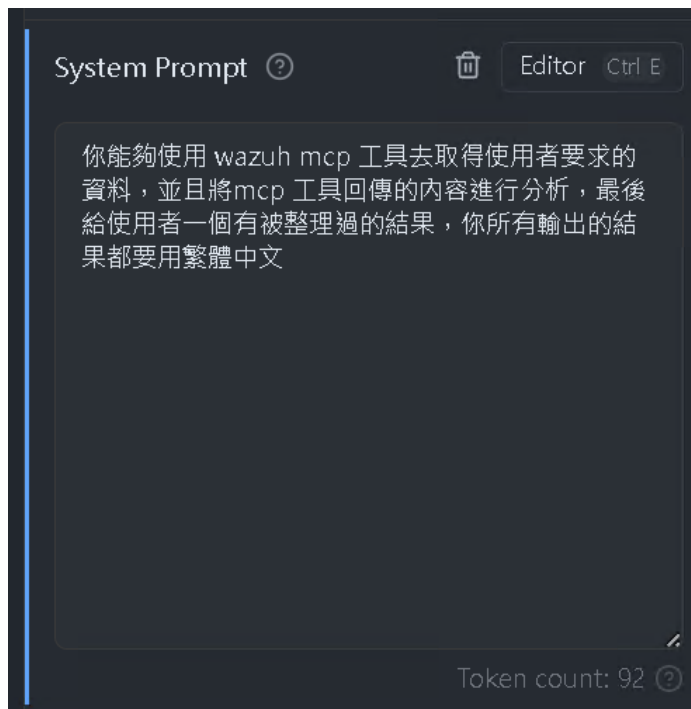
由於我希望使用本地的大語言模型 (LLM) 去跑(當然在 cloude desktop 上我也有跑過)，所以我還要修改軟體(LM studio)裡的 MCP.json 即可。



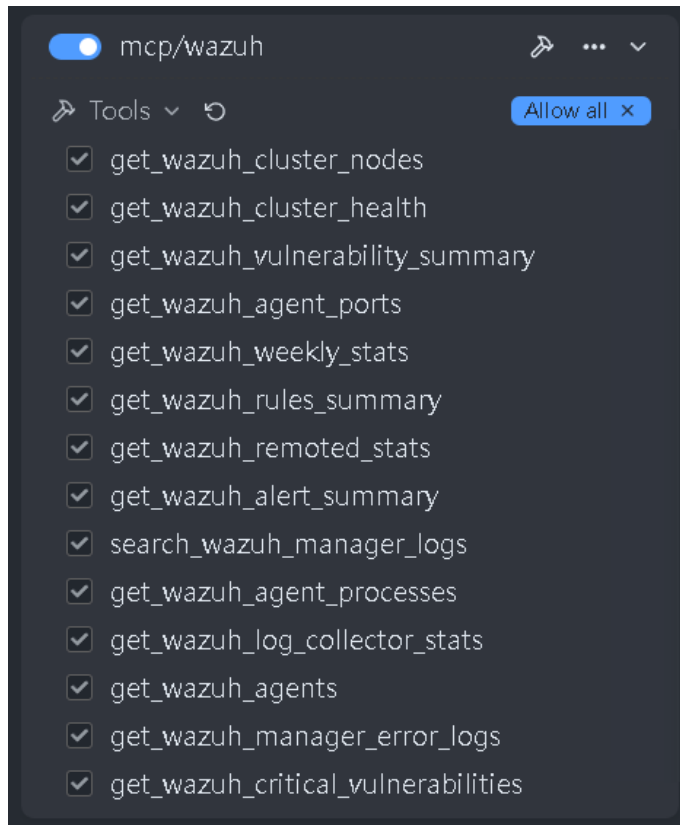
圖三十、mcp.json 的設定

第三節、 結果展示

當然在使用前我就先簡單設定一些基礎的東西，如提示詞、MCP tool 等設定，然後我們就可以正常使用了。



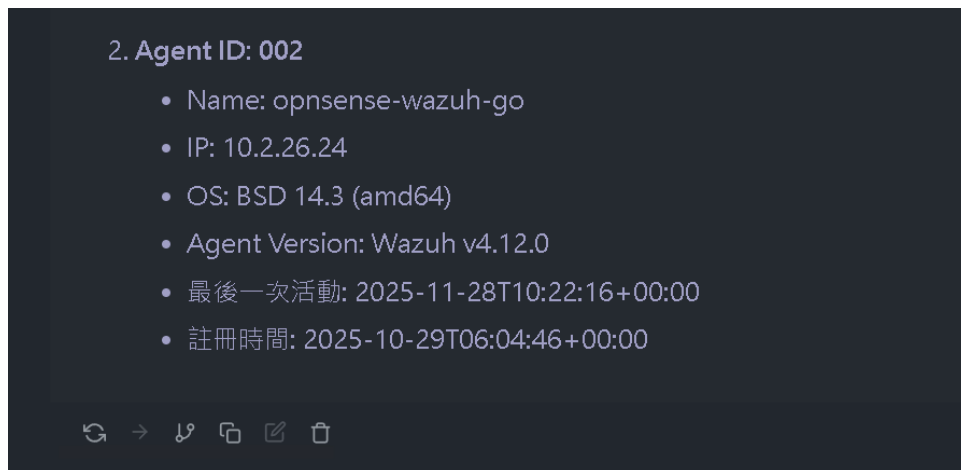
圖三十一、給 AI 的提示詞



圖三十二、AI 可以調用的 MCP 工具



圖三十三、使用自然語言即可得到 wazuh agent 的運行狀態，此為 wazuh server 本身的狀態



圖三十四、同圖十四一同輸出的結果

第四節、問題討論

不過使用後還是會有很多問題，詳見下面幾張附圖



圖三十五、已讀亂回



圖三十六、不會使用 MCP tool



圖三十七、沒看懂使用者輸入

是故，將小語言模型和 MCP server 相結合，如果沒有經過適當的修改，我個人認為較不適合。

第五章、 未來展望